

Committee on National Security Systems

CNSS Advisory Memorandum
Cybersecurity 01-20
January 2020



ADVISORY MEMORANDUM

PATCH CRITICAL CRYPTOGRAPHIC VULNERABILITY IN MICROSOFT WINDOWS CLIENTS AND SERVERS



NATIONAL MANAGER

FOREWORD

1. The Committee on National Security Systems (CNSS) is issuing this Advisory memorandum to inform agencies of updated National Security Agency (NSA) guidance associated with a discovery of a critical vulnerability (CVE-2020-0601) affecting Microsoft Windows cryptographic functionality. The certificate validation vulnerability allows an attacker to undermine how Windows verifies cryptographic trust and can enable remote code execution. This Advisory memorandum establishes mitigating actions and prioritization for NSS. (For additional information please reference NSA CVE-2020-0601).

2. Dissemination of this Advisory Memorandum should be to all Government entities, contractors, or agents engaged in Cybersecurity (CS) activities associated with NSS.

3. In addition to this Advisory Memorandum, further mitigation guidance is available to assist operators and users of NSS with mitigating the threats named herein. The National Security Agency (NSA) is available to provide technical consulting to CNSS members to assist in threat mitigation. For further information, please contact the Cybersecurity Requirements Center at 410.854.4200 or call the Committee on National Security Systems (CNSS) Secretariat at 410.854.6805.

4. Additional copies of this Advisory Memorandum may be obtained.

5. This policy is available from the CNSS Secretariat, as noted below, or the CNSS website: <http://www.cnss.gov>.

FOR THE NATIONAL MANAGER:

/s/

ANNE NEUBERGER

**CNSS Secretariat, National Security Agency, 9800 Savage Road, STE 6165.
Ft Meade, MD 20755-6165
Office: (410) 854-6805
cnss@nsa.gov**

Table of Contents

SECTION I—PURPOSE.....	1
SECTION II—AUTHORITY.....	1
SECTION III—SCOPE.....	1
SECTION IV—POLICY.....	1
SECTION V—RESPONSIBILITIES.....	2
SECTION VI—DEFINITIONS.....	2
SECTION VII – REFERENCES.....	2
ANNEX A: REFERENCES.....	A-1
ANNEX B:DEFINITIONS.....	B-1

ADVISORY MEMORANDUM
PATCH CRITICAL CRYPTOGRAPHIC VULNERABILITY IN MICROSOFT
WINDOWS CLIENTS AND SERVERS

SECTION I—PURPOSE

1. The critical vulnerability affecting Microsoft Windows cryptographic functionality poses a serious risk to the security of NSS and is of great concern to all Executive Departments and Agencies. The vulnerability places Windows endpoints at risk to a broad range of exploitation vectors. The following guidelines are intended to reduce and mitigate the unauthorized release of sensitive or classified data from NSS and thereby increase their security.

SECTION II—AUTHORITY

2. The authority to issue this advisory derives from National Security Directive 42, which outlines the roles and responsibilities for securing national security systems, consistent with applicable law, E.O. 12333, as amended, and other Presidential directives.

3. Nothing in this advisory shall alter or supersede the authorities of the Director of National Intelligence.

SECTION III—SCOPE

4. This guidance is based on current best practices for limiting the security risks to cryptographic functionality of NSS. As stated in Reference four, rapid adoption of the patch is the only known mitigation at this time and should be the primary focus for all network owners.

SECTION IV—POLICY

5. Operators and users of NSS should install all January 2020 Patch Tuesday patches as soon as possible to effectively mitigate the vulnerability on all Windows 10 and Windows Server 2016/2019 systems. In the event that enterprise-wide, automated patching is not possible, NSA recommends system owners prioritize patching endpoints that provide essential or broadly relied-upon services and those that have a high risk of exploitation.

6. Administrators should be prepared to conduct remediation activities since unpatched endpoints may be compromised. Applying patches to all affected endpoints is recommended, when possible, over prioritizing specific classes of endpoints

7. Other actions can be taken to protect endpoints in addition to installing patches. Network devices and endpoint logging features may prevent or detect some methods of exploitation, but installing all patches is the most effective mitigation.

- a. Some enterprises route traffic through existing proxy devices that perform TLS inspection, but do not use Windows for certificate validation. The devices can help isolate vulnerable endpoints behind the proxies while the endpoints are being patched.
- b. Packet capture analysis tools such as Wireshark can be used to parse and extract certificates from network protocol data for additional analysis. Software utilities such as OpenSSL and Windows certutil can be used to perform in-depth analysis of certificates to check for malicious properties.

SECTION V—RESPONSIBILITIES

8. The heads of each Federal department or agency should ensure the implementation of this policy and develop clear and comprehensive implementation guidance in support of current law, policies, regulations, and business rules

SECTION VI—DEFINITIONS

9. The following definitions are provided to clarify the use of specific terms contained in this advisory. All other terms used in this issuance are defined in CNSS Instruction (CNSSI No. 4009, *National IA Glossary*).

SECTION VII - REFERENCES

10. Future updates to referenced documents shall be considered applicable to this advisory.

Enclosures:

ANNEX A - Definitions

ANNEX B - References

ANNEX A

DEFINITIONS

a. (U) Compromise. Disclosure of information or data to unauthorized person(s), or a violation of the security policy of a system in which unauthorized intentional or unintentional disclosure, modification, destruction, or loss of an object or information may have occurred.

ANNEX B

REFERENCES

1. (U) National Security Presidential Directive 54/Homeland Security Presidential Directive 23, Cybersecurity Policy, January 8, 2009.
2. (U) Public Law 107-347 [H.R. 2458], codified at 44 U.S.C. § et seq., The E-Government Act of 2002, Title III, the Federal Information Security Management Act of 2002, December 17, 2002.
3. (U) Committee for National Security Systems Instruction Number 4009 (CNSSI Assurance (IA) Glossary, March 9, 2010.
4. (U) National Security Agency, Cybersecurity Advisory, Patch Critical Cryptographic Vulnerability in Microsoft Windows Clients and Servers, January 14, 2020.